

Unit-02 Policies

2.1 Security Policies

A security policy is a formal set of rules and guidelines designed to protect an organization's network, systems, and data. It defines acceptable behaviours, responsibilities, and security measures to safeguard assets against potential threats.

2.1.1 The Nature of Security Policies

Security policies serve as a blueprint for ensuring the confidentiality, integrity, and availability of information. They aim to:

1. Define security objectives and goals.
2. Establish rules for user behaviour and system usage.
3. Provide a framework for identifying and managing risks.
4. Align with regulatory requirements and organizational needs.

2.1.2 Types of Security Policies

Security policies can be categorized based on their scope and focus:

1. **Organizational Policies:**
 - High-level policies defining the overall security strategy.
 - Example: Acceptable Use Policy (AUP) for using organizational resources.
2. **System-Specific Policies:**
 - Focused on the security requirements of specific systems.
 - Example: Policy for securing a financial database.
3. **Issue-Specific Policies:**
 - Address specific security concerns or technologies.
 - Example: Email usage policy or Bring Your Own Device (BYOD) policy.
4. **Access Control Policies:**
 - Define rules for granting and restricting access to systems or data.
 - Example: Role-Based Access Control (RBAC) policies.

2.1.3 The Role of Trust

Trust is fundamental to security policies, as it determines how much confidence is placed in systems, users, and processes. It includes:

- **Trust Relationships:** Defining which entities (e.g., users, devices, organizations) are considered trustworthy.
- **Minimizing Assumptions:** Designing policies to operate securely even if some trust is violated (e.g., least privilege principle).
- **Periodic Validation:** Regularly auditing and verifying compliance with security policies to maintain trust.

2.1.4 Example: Academic Computer Security Policy

Objective: To ensure the secure use of academic computing resources for education, research, and administration.

1. User Responsibilities:

- Use systems ethically and only for academic purposes.
- Keep passwords confidential and follow password policies.
- Report any suspicious activity to the IT department.

2. Access Control:

- Access granted based on user roles (students, faculty, staff).
- Systems use multi-factor authentication.

3. Data Protection:

- Sensitive academic records (e.g., grades, personal data) must be encrypted.
- Data sharing restricted to authorized users.

4. Monitoring and Enforcement:

- Network activities monitored to detect unauthorized use.
- Violations subject to disciplinary actions, such as access revocation or academic penalties.

2.2 Confidentiality Policies

Confidentiality policies focus on protecting sensitive information from unauthorized access and ensuring that only authorized individuals or systems can view or use specific data. These policies

are crucial for maintaining privacy, compliance with regulations, and safeguarding organizational secrets.

2.2.1 The Bell-LaPadula Model

The **Bell-LaPadula (BLP) Model** is a widely used security model designed to enforce confidentiality in computer systems. It is particularly relevant in systems where data sensitivity levels and user clearance levels must align, such as in military or government environments. It controls access by assigning security levels to both data (called objects) and users or processes (called subjects). The model follows two main rules: the ***Simple Security Property (No Read-Up)***, which means users cannot view information at a higher security level than their clearance, and the *****Property (No Write-Down)***, which stops users from sharing information with lower security levels to prevent leaks. Commonly used in military and government settings, the BLP Model ensures only authorized users can access sensitive information. However, it focuses only on confidentiality and does not cover other aspects like data accuracy or system availability, making it best for environments where protecting classified information is most important.

2.3 Integrity Policies

Integrity policies are designed to ensure the accuracy, consistency, and reliability of data by preventing unauthorized modification. These policies focus on protecting data from corruption, unauthorized changes, or manipulation, thereby maintaining its trustworthiness.

2.3.1 The Biba Model

The **Biba Model** is a security framework designed to protect the integrity of data, ensuring it remains accurate, reliable, and trustworthy. Unlike the Bell-LaPadula Model, which focuses on keeping information confidential, the Biba Model prioritizes preventing unauthorized or accidental changes to data. This is critical in environments where maintaining the correctness of information is more important than restricting access.

The Biba Model uses hierarchical integrity levels to classify both users (subjects) and data (objects). It enforces two main rules to maintain integrity: the ***Simple Integrity Property (No Write-Up)***, which prevents users from writing or modifying data at a higher integrity level than their own, and the ***Star Integrity Property (No Read-Down)***, which stops users from reading data at lower integrity levels to avoid contamination from untrustworthy sources. For example, a low-integrity user cannot update highly reliable data, and a highly trusted user cannot access data from an untrusted source.

This model is widely used in systems where data reliability is crucial, such as financial transactions, medical records, or industrial operations. By ensuring that only authorized users with the appropriate integrity level can modify or access data, the Biba Model protects against errors, tampering, and fraud. However, it focuses solely on integrity and does not address confidentiality or availability, making it best suited for applications where data accuracy is the primary concern.

2.4 Availability Policies

Availability policies are crucial for ensuring that systems, data, and services are accessible and operational when needed. They focus on protecting resources from disruptions, ensuring that they remain reliable, consistent, and can handle high-demand periods without failure.

2.4.1 Goals of Availability Policies

The main goal of availability policies is to ensure that authorized users can access systems, applications, and data at any time, with minimal downtime. The major objectives include:

1. **Ensuring Continuous Service:**

- Preventing service outages, ensuring that critical systems remain accessible during both regular and peak usage times.

2. **Redundancy:**

- Implementing backup systems, failover mechanisms, and disaster recovery plans to maintain functionality even during failures.

3. **Performance Optimization:**

- Ensuring systems can handle high traffic loads efficiently without degrading performance.

4. **Incident Recovery:**

- Minimizing downtime by having quick recovery plans in place after disruptions or failures occur.

5. **Protection Against External Threats:**

- Safeguarding against threats that could lead to downtime, such as cyberattacks, infrastructure failures, or physical damage.

By achieving these goals, availability policies help maintain user access to important services and data, ensuring the smooth operation of business processes.

2.4.2 Denial of Service Models

A **Denial of Service (DoS)** attack is a threat that aims to make a system, service, or network resource unavailable to its intended users. There are different models and techniques for implementing DoS attacks, including:

1. **DoS Attack:**

- A single machine or user overwhelms a target with traffic, making it unresponsive.
- Example: Sending excessive requests to a website to cause server crashes.

2. **Distributed Denial of Service (DDoS) Attack:**

- Involves multiple systems or machines, often compromised through botnets, to simultaneously flood a target with traffic, making it harder to mitigate.
- Example: A DDoS attack targets an online service, overwhelming it with millions of requests.

3. **Resource Exhaustion:**

- Attackers may deplete a system's resources (e.g., CPU, bandwidth, memory), rendering it unusable or slow to respond.
- Example: Consuming all available database connections, preventing legitimate users from accessing the service.

4. **Flooding Attacks:**

- Attackers send large volumes of traffic to flood a network or server, causing congestion and interrupting normal service.

Availability policies often focus on mitigating DoS attacks by employing strategies like load balancing, rate limiting, and implementing DDoS protection services to ensure uninterrupted access to systems.

2.4.3 Example: Availability and Network Flooding

A common example of availability disruption is **network flooding** through a Denial of Service (DoS) or Distributed Denial of Service (DDoS) attack. In such attacks, an attacker sends a massive amount of traffic to a target network or server, overwhelming its resources and causing it to become slow, unresponsive, or even crash entirely. This type of attack disrupts the availability of online services, making them inaccessible to legitimate users.

For example, an e-commerce website may be targeted during a major sales event, flooding its servers with millions of requests and causing the site to go offline. To protect against such attacks, organizations may implement DDoS protection services, use content delivery networks (CDNs) to distribute traffic, and set up firewalls that can detect and block malicious traffic. Availability policies should address these risks by having strategies in place to mitigate flooding attacks, ensuring that services stay online and available even during high-traffic periods or attack scenarios.
